Partie 1 — Le cours

Séances 2 et 3 · Technologies, zones de confiance, DMZ, VLAN, segmentation et pare-feu. Cochez « J'ai lu cette partie » au fil de votre lecture : votre progression est enregistrée.

0. Objectifs et compétences visées

À l'issue des deux séances, vous devez être capable de :

- identifier le rôle de chaque équipement (pare-feu, switch, routeur, serveur) dans une architecture sécurisée ;
- définir des zones de confiance et placer les services dans la bonne zone ;
- concevoir une DMZ et justifier sa position ;
- segmenter un réseau par VLAN et établir une matrice de flux ;
- écrire des règles de filtrage selon le principe du moindre privilège ;
- comparer une architecture plate et une architecture segmentée (risque de propagation latérale) ;
- produire un schéma d'architecture annoté et justifier vos choix.

Ces notions relèvent du bloc cybersécurité du BTS SIO (option SISR en particulier) : sécurisation des équipements et des accès, protection des données, gestion des risques.

1. Pourquoi une architecture sécurisée ?

Un réseau « plat », où tout communique avec tout, est simple à installer mais très fragile : la compromission d'un seul poste (hameçonnage, clé USB, vulnérabilité) permet à l'attaquant d'atteindre l'ensemble du système d'information. L'architecture sécurisée repose sur trois idées directrices :

- **Défense en profondeur** : empiler plusieurs barrières indépendantes (pare-feu, segmentation, durcissement des serveurs, supervision). Si l'une tombe, les autres limitent les dégâts.
- **Moindre privilège** : chaque utilisateur, machine ou flux n'a que les droits strictement nécessaires.
- **Cloisonnement** : on sépare les systèmes selon leur niveau de sensibilité et d'exposition.

On raisonne avec les critères **DICT** : Disponibilité, Intégrité, Confidentialité, Traçabilité. L'architecture doit protéger ces quatre propriétés.

2. Les équipements

2.1 Le pare-feu (firewall)

Il filtre les flux entre des zones réseau selon des règles.

Type	Principe	Limite
Sans état (stateless)	Examine chaque paquet isolément (IP, port, protocole)	Ne comprend pas la notion de connexion
À états (stateful)	Suit l'état des connexions (table de sessions) ; les réponses sont autorisées automatiquement	Ne voit pas le contenu applicatif
Applicatif / NGFW	Analyse la couche 7 : application, utilisateur, IPS, filtrage d'URL, inspection TLS	Coût et impact sur les performances
WAF	Protège les applications web (injections SQL, XSS)	Ne protège que le trafic HTTP(S)

- chaque interface du pare-feu appartient à une zone (WAN, LAN, DMZ…) ;
- la politique par défaut doit être **deny all** : tout est interdit sauf ce qui est explicitement autorisé ;
- les règles sont lues de haut en bas, **la première qui correspond s'applique** ;
- tout est journalisé et envoyé vers un serveur central (syslog / SIEM).

Exemples : pfSense, OPNsense, Fortinet FortiGate, Palo Alto, Stormshield, Cisco ASA/FTD, iptables / nftables.

2.2 Le switch (commutateur)

Il travaille principalement en couche 2 (adresses MAC) ; un switch de niveau 3 sait aussi router entre VLAN. Fonctions de sécurité à connaître :

- **VLAN** : séparation logique des domaines de diffusion ;
- **Port security** : limite le nombre ou la liste d'adresses MAC par port ;
- **802.1X** : authentification d'un équipement avant l'accès au réseau (avec un serveur RADIUS) ;
- **DHCP snooping** et **Dynamic ARP Inspection** : contrent les faux serveurs DHCP et l'usurpation ARP ;
- **BPDU guard / root guard** : protègent le protocole Spanning Tree ;
- désactivation des ports inutilisés, placés dans un VLAN « poubelle » ;
- administration par SSH uniquement, jamais Telnet.

2.3 Le routeur

Il achemine les paquets entre réseaux (couche 3). Il peut porter des ACL, du NAT et des tunnels VPN. Dans les petites structures, routeur et pare-feu sont souvent le même équipement.

2.4 Les serveurs

Chaque serveur doit être durci (*hardening*) : suppression des services et comptes inutiles ; mises à jour régulières ; pare-feu local ; authentification forte, comptes nominatifs, droits minimaux ; journalisation et sauvegardes testées ; un serveur = une fonction principale.

2.5 Équipements complémentaires

- **Reverse-proxy** : reçoit les requêtes externes à la place des serveurs internes, termine le TLS, filtre et répartit la charge (Nginx, HAProxy, Apache) ;
- **Proxy sortant** : contrôle la navigation des utilisateurs ;
- **IDS / IPS** : détection / prévention d'intrusion (Suricata, Snort) ;
- **Passerelle VPN** : accès distant chiffré (IPsec, OpenVPN, WireGuard) ;
- **SIEM / syslog** : centralisation et corrélation des journaux ;
- **Bastion** : point de passage obligatoire et tracé pour l'administration.

3. Les zones de confiance

Une **zone de confiance** est un ensemble de machines partageant le même niveau de sensibilité et les mêmes règles de sécurité. Les flux entre zones passent par un point de contrôle (pare-feu).

Zone	Contenu	Niveau de confiance
Internet (WAN)	Réseau public	Nul
DMZ	Services exposés (web, mail, reverse-proxy, VPN)	Faible : zone exposée, présumée compromettable
LAN utilisateurs	Postes de travail	Moyen
Zone serveurs internes	AD, fichiers, bases de données, applications métier	Élevé
Management	Interfaces d'administration, supervision, bastion	Très élevé
Invités (guests)	Wi-Fi visiteurs	Faible, accès Internet uniquement

Règle sur le sens des flux
Une zone de confiance plus faible ne doit pas pouvoir initier de connexion vers une zone plus sensible. Les flux autorisés sont définis explicitement dans une matrice de flux.

4. Première approche de la DMZ

La **DMZ** (zone démilitarisée) est un réseau intermédiaire entre Internet et le réseau interne, destiné à héberger les services qui doivent être accessibles depuis l'extérieur.

Idée clé
Un serveur exposé à Internet sera tôt ou tard attaqué. On l'isole donc pour que, s'il est compromis, l'attaquant ne puisse pas rebondir facilement vers le réseau interne.

- Internet peut accéder aux services de la DMZ, uniquement sur les ports publiés ;
- la DMZ ne peut pas initier de connexion vers le LAN (ou seulement des flux très précis et justifiés) ;
- le LAN peut accéder à la DMZ (administration, mises à jour) ;
- aucune donnée sensible n'est stockée en DMZ.

Cette version à un seul pare-feu à trois interfaces (WAN / DMZ / LAN) est la première approche ; elle est approfondie ci-dessous.

Activité
À partir d'un cas d'entreprise (50 postes, un site web, une messagerie, un AD) : 1) listez les équipements et les services ; 2) classez chaque élément dans une zone de confiance ; 3) esquissez un schéma à trois zones (WAN / DMZ / LAN).

Vos notes (enregistrées automatiquement)...

5. Objectifs et positionnement de la DMZ

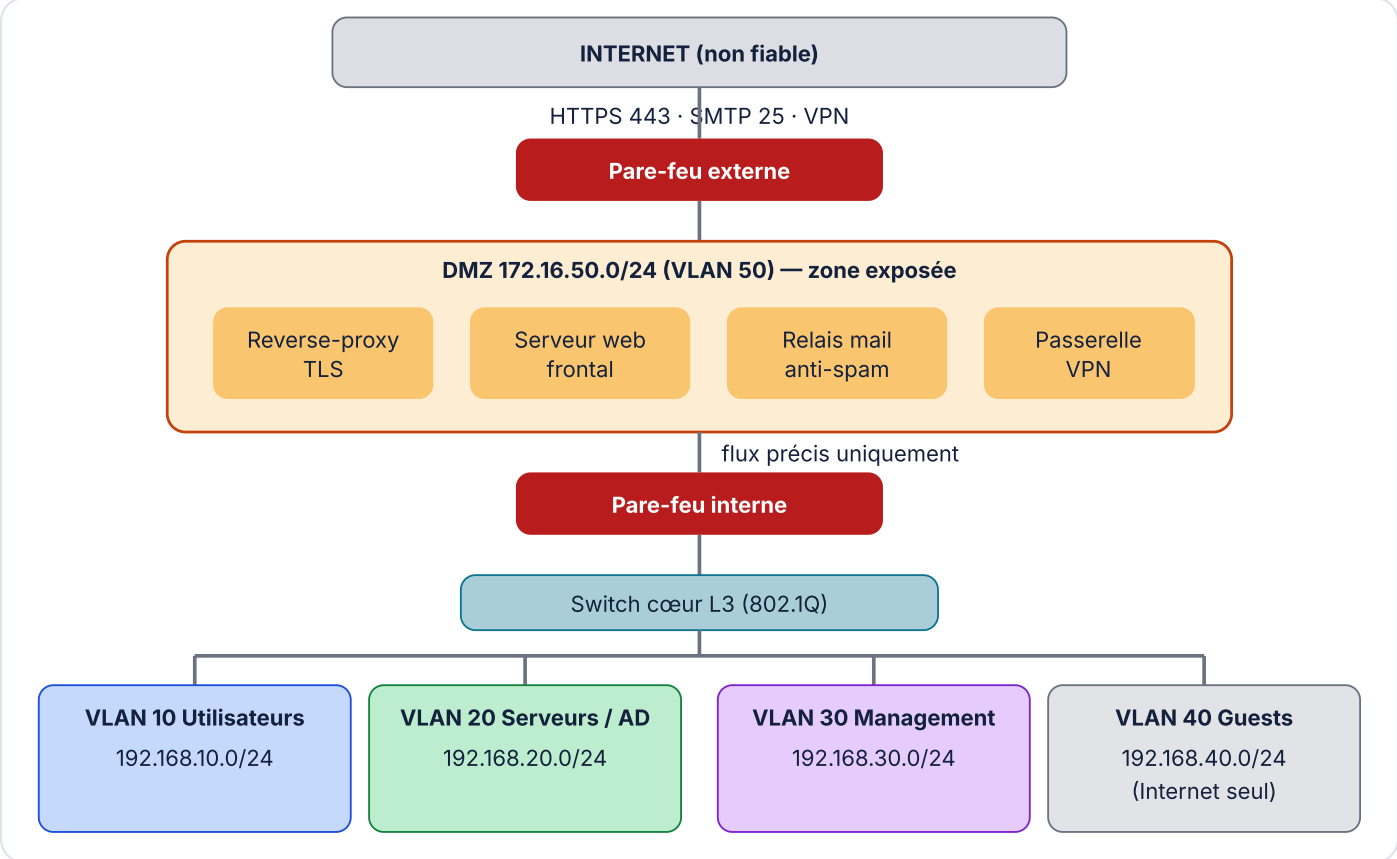
Objectifs : exposer des services sans exposer le réseau interne ; limiter la surface d'attaque ; contenir une compromission ; centraliser la surveillance des flux exposés.

Modèle	Description	Avantages	Inconvénients

DMZ sur interface dédiée (pare-feu « à 3 pattes »)	Un seul pare-feu, trois interfaces : WAN, DMZ, LAN	Simple, économique	Point de défaillance unique ; une faille du pare-feu expose tout
Double pare-feu (DMZ « en sandwich »)	Pare-feu externe, DMZ, pare-feu interne	Meilleure défense en profondeur ; technologies différentes possibles	Coût et complexité

Le modèle à double pare-feu est celui retenu comme architecture type du cours.

6. Architecture type



Lecture : Internet ↔ Pare-feu ↔ DMZ ↔ Pare-feu ↔ Réseau interne ↔ VLAN serveurs / AD. Les flux initiés du moins fiable vers le plus sensible sont interdits par défaut.

> **Pourquoi deux pare-feu ?**
> Un attaquant doit franchir deux barrières distinctes. Si le pare-feu externe est contourné, la DMZ reste isolée du réseau interne par le second, idéalement d'un autre constructeur pour éviter une faille commune.

7. Segmentation par VLAN

Un **VLAN** (Virtual LAN, norme IEEE 802.1Q) découpe un switch en plusieurs réseaux logiques indépendants. Chaque VLAN correspond à un sous-réseau IP distinct, et le trafic inter-VLAN passe obligatoirement par un équipement de niveau 3 (switch L3 ou pare-feu) où l'on applique le filtrage.

7.1 Plan de segmentation type

VLAN	Nom	Sous-réseau	Contenu
10	Utilisateurs	192.168.10.0/24	Postes de travail
20	Serveurs	192.168.20.0/24	AD, fichiers, bases de données, applications
30	Management	192.168.30.0/24	Administration des équipements, supervision, bastion
40	Guests	192.168.40.0/24	Wi-Fi invités, accès Internet seulement
50	DMZ	172.16.50.0/24	Services exposés
99	Poubelle	—	Ports inutilisés, désactivés

7.2 Notions techniques

- **Port d'accès (access)** : appartient à un seul VLAN, pour un poste ou un serveur ;
- **Port trunk** : transporte plusieurs VLAN, avec étiquette 802.1Q, entre switchs ou vers le pare-feu ;
- **VLAN natif** : à changer (pas le VLAN 1) et à ne pas utiliser pour des données ;
- **Routage inter-VLAN** : « router-on-a-stick » (sous-interfaces sur le pare-feu) ou interfaces virtuelles (SVI) sur un switch L3.

7.3 Attaques à connaître

- **VLAN hopping** (switch spoofing, double tagging) : parade = désactiver la négociation DTP, fixer les ports en mode access, changer le VLAN natif ;
- **ARP spoofing, DHCP spoofing** : parade = Dynamic ARP Inspection, DHCP snooping ;
- accès non autorisé par une prise réseau : parade = 802.1X, port security.

> **À retenir**
> Un VLAN n'est pas une barrière de sécurité à lui seul : c'est le filtrage entre VLAN qui apporte la sécurité.

8. Règles de filtrage

8.1 Principes

1. Politique par défaut : **deny all**, puis on autorise le strict nécessaire (liste blanche).
2. **Moindre privilège** : on précise source, destination, protocole et port ; on évite « any ».
3. **Sens des flux** : on définit qui initie la connexion. Avec un pare-feu à états, les réponses sont autorisées automatiquement.
4. Ports strictement nécessaires : chaque règle est justifiée, documentée et revue périodiquement.
5. Journalisation des refus et des flux sensibles.
6. Ordre des règles : du plus spécifique au plus général, la règle finale étant le refus.

8.2 Matrice de flux (exemple)

Source	Destination	Service / port	Décision	Justification
Internet	Reverse-proxy (DMZ)	TCP 443	Autorisé	Publication du site web en HTTPS
Internet	Relais mail (DMZ)	TCP 25	Autorisé	Réception des mails
Internet	VPN (DMZ)	UDP 1194 / 51820	Autorisé	Accès distant des nomades
Internet	LAN / serveurs	Tous	Refusé	Aucun accès direct au réseau interne
Reverse-proxy (DMZ)	Serveur applicatif interne	TCP 8080	Autorisé	Flux précis, une seule destination
Relais mail (DMZ)	Messagerie interne	TCP 25	Autorisé	Remise des mails entrants
DMZ	VLAN Utilisateurs	Tous	Refusé	Empêcher le rebond depuis une zone exposée
VLAN Utilisateurs	Internet	TCP 80/443, DNS	Autorisé (via proxy)	Navigation

VLAN Utilisateurs	VLAN Serveurs	SMB 445, LDAP / Kerberos selon besoin	Autorisé (précis)	Ressources et AD
VLAN Utilisateurs	VLAN Management	Tous	Refusé	Aucun accès à l'administration
VLAN Management	Tous les VLAN	SSH 22, RDP 3389, SNMPv3	Autorisé (source limitée)	Administration depuis le bastion seulement
VLAN Guests	Internet	TCP 80/443, DNS	Autorisé	Accès visiteurs
VLAN Guests	Réseaux internes	Tous	Refusé	Isolation totale
Serveurs	Internet	443 via proxy	Autorisé (limité)	Mises à jour uniquement

8.3 Exemple de règles (syntaxe générique)

```
# Règle 10 : publier le site en HTTPS
allow tcp from any to 172.16.50.10 port 443 log
# Règle 20 : reverse-proxy vers l'application interne
allow tcp from 172.16.50.10 to 192.168.20.20 port 8080
# Règle 99 : refus par défaut
deny ip from any to any log
```

9. Architecture plate vs architecture segmentée

Critère	Architecture plate	Architecture segmentée
Principe	Un seul réseau pour tous	Zones et VLAN séparés, filtrage entre zones
Propagation latérale	Très facile : un poste compromis atteint tous les serveurs	Limitée : chaque saut est contrôlé par le pare-feu
Surface d'attaque	Large	Réduite

Détection	Difficile (flux mélangés)	Facilitée (flux inter-zones journalisés)
Impact d'un ransomware	Chiffrement potentiel de tout le SI	Cantonné à la zone touchée
Conformité (RGPD, ISO 27001, ANSSI)	Insuffisante	Recommandée
Complexité et coût	Faibles	Plus élevés (conception, administration)
Performances	Aucun filtrage interne	Léger surcoût de filtrage

Propagation latérale (*lateral movement*) : après une première intrusion, l'attaquant explore le réseau, vole des identifiants, puis se déplace de machine en machine jusqu'aux cibles de valeur (AD, bases de données). La segmentation multiplie les obstacles et les points de détection.

> **Exemple concret**
> Dans un réseau plat, un poste infecté par un ransomware peut chiffrer les partages du serveur de fichiers et atteindre l'AD. Dans un réseau segmenté, le poste n'a accès au serveur de fichiers que par les ports strictement nécessaires, l'AD est dans un VLAN protégé et les sauvegardes dans une zone dédiée.

10. Services placés en DMZ

Service	Rôle	Bonnes pratiques
Serveur web	Site vitrine, portail	HTTPS, WAF, pas de base de données locale ; la base reste en zone interne, accessible par un flux précis
Reverse-proxy	Point d'entrée unique, terminaison TLS, filtrage	Masque l'architecture interne, répartition de charge, limitation de débit
Relais de messagerie	Reçoit et filtre les mails avant remise	SPF, DKIM, DMARC, antivirus, anti-spam
Passerelle VPN	Accès distant sécurisé	Authentification multifacteur, droits limités par profil
DNS public (autoritaire)	Résolution des noms de l'entreprise	Séparé du DNS interne (split DNS)

Serveur SFTP	Échange de fichiers avec des partenaires	SFTP uniquement, comptes isolés

À ne pas mettre en DMZ

L'annuaire Active Directory, les bases de données de production, les serveurs de fichiers internes, les sauvegardes.

11. Durcissement et surveillance de la DMZ

- serveurs minimalistes, à jour, sans compte inutile ;
- IDS / IPS sur les flux entrants ;
- journaux envoyés vers un SIEM situé en zone interne ;
- tests réguliers : scan de vulnérabilités, test d'intrusion ;
- plan de réaction en cas de compromission : isoler la DMZ en coupant les règles du pare-feu interne.

12. Livrable : schéma d'architecture annoté

Un schéma (draw.io, Packet Tracer, Visio, Lucidchart) faisant apparaître : les zones avec une couleur par niveau de confiance ; les équipements (pare-feu externe et interne, switch cœur, serveurs, reverse-proxy, VPN, bastion) ; les flux fléchés (sens d'initiation, protocole, port) ; le plan d'adressage et les numéros de VLAN. Il est accompagné d'une matrice de flux et d'une justification des choix.

Plan type de justification

- Contexte et besoins : taille de l'entreprise, services à exposer, données sensibles ;
- Risques identifiés : intrusion externe, propagation latérale, ransomware, fuite de données ;
- Choix d'architecture : pourquoi un double pare-feu, pourquoi ces VLAN, pourquoi tel service en DMZ ;
- Politique de filtrage : deny all, moindre privilège, ports retenus ;
- Mesures complémentaires : durcissement, supervision, sauvegardes, 802.1X, MFA ;
- Limites et améliorations : coûts, évolutions possibles (zero trust, microsegmentation).

Critère d'évaluation indicatif	Points
Zones et équipements cohérents et complets	5

Flux représentés et justes (sens, ports)	5
Respect du moindre privilège	4
Justification argumentée des choix	4
Qualité et lisibilité du schéma	2
Total	**20**

13. Exercices corrigés

Essayez de répondre avant d'ouvrir la correction.

▼ Exercice 1 — Un serveur web en DMZ doit interroger une base de données interne. Quelle règle écrire ?

Autoriser uniquement serveur web (DMZ) vers serveur BDD (VLAN serveurs) sur le port du SGBD (par exemple TCP 3306 ou 5432), via le pare-feu interne ; aucun autre flux DMZ vers interne. Mieux encore : placer un serveur applicatif intermédiaire pour ne pas exposer directement la base.

▼ Exercice 2 — Pourquoi le VLAN Guests ne doit-il pas pouvoir joindre le VLAN Serveurs ?

Les invités sont des équipements non maîtrisés, potentiellement infectés ou malveillants ; leur donner accès aux serveurs violerait le moindre privilège et créerait un chemin de propagation.

▼ Exercice 3 — Un poste du VLAN Utilisateurs est compromis. Citez trois mesures de l'architecture qui limitent l'impact.

Filtrage inter-VLAN (ports précis vers les serveurs), VLAN Management inaccessible aux utilisateurs, journalisation et détection des flux anormaux, 802.1X et comptes à privilèges limités, sauvegardes isolées.

▼ Exercice 4 — Quelle est la différence entre un VLAN et une DMZ ?

Le VLAN est un mécanisme technique de séparation de couche 2 ; la DMZ est un concept de zone de sécurité destinée aux services exposés, qui s'implémente souvent à l'aide d'un VLAN dédié et de règles de pare-feu.

14. Points clés à retenir

- Défense en profondeur, moindre privilège, cloisonnement.
- Pare-feu : deny all par défaut, règles précises, journalisation.
- Zones de confiance : une zone moins fiable n'initie pas de flux vers une zone plus sensible.
- DMZ : services exposés isolés, double pare-feu pour une meilleure protection.
- VLAN : séparation logique, utile seulement avec un filtrage entre VLAN.
- Architecture segmentée : limite la propagation latérale et l'impact d'un incident.
- Le livrable doit montrer et justifier : un schéma sans justification est incomplet.

15. Lexique

Terme	Définition
802.1Q	Norme IEEE de balisage des VLAN : ajoute une étiquette (tag) dans la trame Ethernet.
802.1X	Contrôle d'accès au réseau par port : l'équipement s'authentifie (souvent via RADIUS).
ACL	Liste de règles autorisant ou refusant des flux sur un routeur ou un switch.
AD (Active Directory)	Annuaire Microsoft centralisant utilisateurs, machines et droits.
ARP spoofing	Usurpation ARP : l'attaquant associe sa MAC à l'IP d'une autre machine.
Bastion	Serveur de rebond obligatoire et journalisé pour administrer les équipements sensibles.
BPDU guard	Protection d'un port d'accès contre des trames Spanning Tree non attendues.
Cloisonnement	Séparation des systèmes selon leur sensibilité pour limiter la propagation d'un incident.
DHCP snooping	Le switch n'autorise les réponses DHCP que depuis des ports de confiance.
DICT	Disponibilité, Intégrité, Confidentialité, Traçabilité.

Défense en profondeur	Superposition de plusieurs couches de protection indépendantes.
DMZ	Zone démilitarisée : réseau intermédiaire hébergeant les services exposés.
Deny all	Politique par défaut refusant tout flux non explicitement autorisé.
Split DNS	Séparation entre DNS public (zone exposée) et DNS interne.
Durcissement (hardening)	Réduction de la surface d'attaque : services, comptes et ports inutiles supprimés.
IDS / IPS	Détection / prévention d'intrusion.
Moindre privilège	Ne donner que les droits strictement nécessaires.
Matrice de flux	Tableau listant source, destination, protocole, port et décision.
MFA	Authentification multifacteur.
NAT	Traduction d'adresses : remplace les adresses IP privées par une adresse publique, et inversement.
NGFW	Pare-feu applicatif avec IPS, filtrage d'URL, identification des utilisateurs.
Port security	Limite les adresses MAC autorisées sur un port du switch.
Propagation latérale	Déplacement d'un attaquant de machine en machine après une première intrusion.
Pare-feu stateful	Suit les connexions et autorise automatiquement les réponses.
RADIUS	Protocole d'authentification centralisée des accès réseau.
Reverse-proxy	Serveur frontal recevant les requêtes externes et les relayant vers des serveurs internes.
Router-on-a-stick	Routage inter-VLAN via des sous-interfaces sur un seul lien trunk.
SIEM	Collecte, corrèle et analyse les journaux.
SPF / DKIM / DMARC	Authentification des domaines de messagerie contre l'usurpation.
SVI	Interface de niveau 3 d'un VLAN sur un switch L3.
Surface d'attaque	Ensemble des points par lesquels un attaquant peut tenter d'entrer.

Trunk	Lien transportant plusieurs VLAN entre deux équipements.
VLAN hopping	Attaque permettant de sortir de son VLAN (switch spoofing, double tagging).
VPN	Tunnel chiffré entre un utilisateur ou un site et le réseau de l'entreprise.
WAF	Filtre les attaques visant les applications web.
Zero trust	Aucun flux ni utilisateur n'est approuvé par défaut : vérification systématique.
Zone de confiance	Ensemble de systèmes partageant le même niveau de sensibilité et les mêmes règles.

Pour aller plus loin : guides de l'ANSSI (architecture d'un système d'information, guide d'hygiène informatique, sécurisation de l'administration) ; Packet Tracer, GNS3, pfSense / OPNsense, Wireshark.

FAQ — Questions d'un novice

Les questions que se pose naturellement un étudiant qui découvre l'architecture sécurisée. Cliquez sur une question pour afficher la réponse.

Concepts de base

▼ Q1. C'est quoi exactement une « architecture sécurisée » ?

C'est l'organisation du réseau de façon à ce qu'un problème sur une machine (poste infecté, serveur web piraté…) ne permette pas à l'attaquant d'atteindre facilement tout le reste. On sépare les zones, on filtre les flux et on applique le moindre privilège.

▼ Q2. Pourquoi on ne laisse pas tout le monde communiquer avec tout le monde ?

Un réseau « plat » est très fragile. Si un seul poste est compromis (clé USB, phishing…), l'attaquant peut se déplacer latéralement et atteindre les serveurs critiques (Active Directory, bases de données…).

▼ **Q3. C'est quoi la « défense en profondeur » ?**

Empiler plusieurs protections indépendantes (pare-feu + segmentation + durcissement des serveurs + supervision…). Si une barrière tombe, les autres limitent les dégâts.

▼ **Q4. C'est quoi le « moindre privilège » ?**

Chaque utilisateur, machine et flux n'a que les droits strictement nécessaires. On n'ouvre jamais « any → any » sur un pare-feu.

▼ **Q5. À quoi servent les critères DICT ?**

Disponibilité, Intégrité, Confidentialité, Traçabilité : l'architecture doit protéger ces quatre propriétés.

Les couches du modèle OSI

▼ **Q6. Il y a combien de couches dans le modèle OSI ?**

7 couches (Open Systems Interconnection), le modèle de référence en formation réseau et cybersécurité.

▼ **Q7. Quelles sont les 7 couches ?**

7 Application (HTTP, DNS, SMTP) · 6 Présentation (TLS, JPEG) · 5 Session (RPC) · 4 Transport (TCP, UDP, ports) · 3 Réseau (IP, routeur, switch L3, pare-feu) · 2 Liaison de données (Ethernet, MAC, switch, VLAN) · 1 Physique (câbles, fibre). Les couches 2 et 3 sont le cœur du cours.

▼ **Q8. C'est quoi la « couche 3 » ?**

La couche Réseau : elle utilise les adresses IP et permet à des machines de réseaux différents de communiquer (routage). Routeurs, switchs L3 et pare-feu y travaillent.

▼ **Q9. Quelle différence entre couche 2 et couche 3 ?**

Couche 2 : adresses MAC, même réseau local (même VLAN), équipement typique = switch.
Couche 3 : adresses IP, communication entre réseaux différents, équipement typique = routeur / switch L3 / pare-feu.

▼ **Q10. Le cours concerne-t-il toutes les couches ?**

Non : surtout les couches 2 et 3, avec des extensions vers la couche 4 (ports) et la couche 7 (services, NGFW, WAF).

Switch et VLAN

▼ **Q11. Quelle différence entre un hub et un switch ?**

Le hub diffuse à tout le monde (peu sécurisé, collisions) ; le switch lit l'adresse MAC de destination et n'envoie la trame qu'au destinataire (plus performant et plus sûr).

▼ **Q12. Qu'est-ce qu'un VLAN ?**

Une technologie qui découpe un switch physique en plusieurs sous-réseaux logiques étanches. Il faut un switch manageable, et si deux VLAN doivent communiquer, le trafic passe obligatoirement par un routeur ou un switch L3. Un VLAN n'est pas une barrière de sécurité à lui seul : c'est le filtrage entre VLAN qui protège.

▼ **Q13. Pourquoi créer un VLAN Management, Guests, poubelle... ?**

Management : isole l'administration et la supervision. Guests : Wi-Fi visiteurs, Internet uniquement. Poubelle : ports inutilisés (désactivés). On change aussi le VLAN natif (souvent 1 par défaut) pour limiter le VLAN hopping.

Les types de pare-feu

▼ **Q14. Un pare-feu, ça fait quoi concrètement ?**

Il regarde les flux entre les zones et décide de les autoriser ou de les bloquer selon des règles : c'est le point de contrôle obligatoire entre les zones de confiance.

▼ **Q15. Quels sont les principaux types de pare-feu ?**

Sans état (paquet par paquet), à états (suit les connexions), applicatif / NGFW (couche 7, IPS, inspection TLS), WAF (applications web : injection SQL, XSS).

▼ Q16. Différence entre stateless et stateful ?

Stateless : chaque paquet est examiné isolément, il faut des règles dans les deux sens. Stateful : une table de sessions ; une fois la connexion autorisée, les réponses passent automatiquement. C'est le type le plus courant.

▼ Q17. C'est quoi un NGFW ?

Next-Generation Firewall : il analyse aussi la couche 7 (application, utilisateur, IPS, inspection TLS). Plus précis, mais plus cher et plus gourmand.

▼ Q18. C'est quoi un WAF ?

Web Application Firewall : protège uniquement les applications web. Il complète le pare-feu réseau, souvent placé devant les serveurs web en DMZ.

▼ Q19. Pare-feu matériel ou logiciel ?

Matériel : boîtier dédié entre les zones (Fortinet, Palo Alto, Stormshield, pfSense…). Logiciel : programme sur la machine (Windows Firewall, iptables…). En entreprise on utilise les deux.

▼ Q20. Pourquoi « deny all » par défaut ?

Tout ce qui n'est pas explicitement autorisé est interdit (liste blanche) : c'est plus sûr que d'interdire au cas par cas.

▼ Q21. Comment le pare-feu lit-il ses règles ?

De haut en bas ; la première règle qui correspond s'applique, puis on s'arrête. L'ordre est donc très important.

Pare-feu et antivirus

▼ Q22. Quelle différence entre pare-feu et antivirus ?

Le pare-feu filtre le trafic réseau entrant et sortant (cible : connexions, adresses IP, ports) comme un garde-frontière. L'antivirus analyse les fichiers et programmes présents sur l'appareil (cible : virus, vers, chevaux de Troie, ransomwares) comme une sentinelle interne. Ils sont complémentaires : le pare-feu stoppe la menace avant la porte, l'antivirus la neutralise si elle s'est installée.

Le proxy

▼ Q23. C'est quoi un proxy ?

Un serveur mandataire : un intermédiaire entre votre appareil et Internet. Votre requête est envoyée au proxy, qui la transmet au site, reçoit la réponse et vous la renvoie. Le site ne voit que l'adresse IP du proxy.

▼ Q24. À quoi sert un proxy ?

Masquer l'adresse IP, filtrer le contenu (entreprises, écoles), mettre en cache des pages pour économiser de la bande passante, contourner des restrictions géographiques.

▼ Q25. Quels sont les principaux types de proxy ?

Proxy web (forward proxy), proxy transparent (sans configuration côté utilisateur), proxy anonyme (cache l'IP mais signale l'usage d'un proxy), proxy inverse (reverse proxy, placé devant des serveurs web).

▼ Q26. Proxy vs VPN ?

Le proxy s'applique souvent à une application ou un navigateur et ne chiffre pas systématiquement ; le VPN chiffre l'intégralité du trafic de l'appareil et offre une sécurité globale bien supérieure.

▼ **Q27. Comment configurer un proxy ?**

Il faut l'adresse (IP ou nom), le port (souvent 8080, 3128 ou 80) et éventuellement un identifiant. Windows : Paramètres → Réseau et Internet → Proxy → Configuration manuelle, activer « Utiliser un serveur proxy », saisir adresse et port. macOS : Réglages Système → Réseau → connexion active → Détails → Proxys. Chrome et Edge utilisent les réglages du système ; Firefox a les siens (Paramètres → Général → Paramètres réseau → Configuration manuelle du proxy).

▼ **Q28. C'est quoi un bastion ?**

Un serveur (ou une zone) par lequel passent obligatoirement toutes les connexions d'administration, toutes tracées. On n'administre plus les équipements directement depuis Internet ou le LAN utilisateurs.

▼ **Q29. À quoi sert un reverse-proxy ?**

Il reçoit les requêtes d'Internet à la place des vrais serveurs web, termine le TLS, filtre et peut répartir la charge. Les serveurs réels restent protégés derrière.

Zones de confiance et DMZ

▼ **Q30. C'est quoi une zone de confiance ?**

Un ensemble de machines qui ont le même niveau de sensibilité et les mêmes règles de sécurité. Les flux entre zones passent obligatoirement par un pare-feu.

▼ **Q31. Pourquoi mettre les services exposés dans une DMZ ?**

Un serveur accessible depuis Internet sera tôt ou tard attaqué. En DMZ, même compromis, l'attaquant n'a pas d'accès direct au réseau interne.

▼ **Q32. La DMZ est-elle « sûre » ?**

Non, on la considère comme compromettable. C'est pourquoi on interdit (ou on limite très fortement) les connexions de la DMZ vers le LAN.

▼ **Q33. Stocke-t-on des données sensibles en DMZ ?**

Jamais. Les bases de données et fichiers importants restent dans le réseau interne.

▼ **Q34. Pourquoi un double pare-feu ?**

Avec un seul pare-feu, s'il est contourné tout est exposé. Avec deux, l'attaquant doit franchir deux barrières distinctes : défense en profondeur.

▼ **Q35. Peut-on mettre l'Active Directory en DMZ ?**

Non : l'AD est critique, il reste dans la zone serveurs internes. Règle d'or : une zone de confiance plus faible ne doit pas pouvoir initier de connexion vers une zone plus sensible.

Règles de filtrage et sens des flux

▼ **Q36. Comment écrire une bonne règle de pare-feu ?**

On précise source + destination + protocole + port, on évite « any », on part de « deny all » puis on ouvre uniquement le nécessaire.

▼ **Q37. Pourquoi s'intéresse-t-on au sens des flux ?**

Une zone peu fiable ne doit pas pouvoir initier de connexion vers une zone plus sensible. Exemple : la DMZ ne doit pas se connecter librement au LAN.

▼ **Q38. Avec un pare-feu stateful, faut-il autoriser les réponses ?**

Non : une fois la connexion autorisée dans un sens, les paquets de réponse sont acceptés automatiquement.

▼ **Q39. Peut-on autoriser « any → any » sur le port 443 ?**

Non. Même sur 443, on limite les sources et les destinations ; « any → any » est presque toujours une mauvaise idée.

Architecture plate vs segmentée

▼ **Q40. Qu'est-ce qu'une architecture plate ?**

Tout est dans le même réseau, tout le monde peut communiquer avec tout le monde. Simple à installer, très risqué en cas de compromission.

▼ **Q41. Quel est son principal danger ?**

La propagation latérale : une fois un poste infecté, l'attaquant atteint facilement les serveurs critiques.

▼ **Q42. Pourquoi l'architecture segmentée est-elle meilleure ?**

Elle limite les mouvements de l'attaquant : même s'il compromet un poste, il se heurte à des filtres avant d'atteindre l'AD ou les bases de données.

Questions pratiques — le livrable

▼ **Q43. Que dois-je obligatoirement faire apparaître dans le schéma ?**

Les zones (Internet, DMZ, LAN utilisateurs, serveurs, management, guests), les pare-feu (externe et interne de préférence), les VLAN avec leurs sous-réseaux, les principaux services, les flux autorisés et une légende claire.

▼ **Q44. Comment justifier mes choix ?**

Expliquer pourquoi tel service est en DMZ, pourquoi deux pare-feu, pourquoi ces VLAN, quelles règles principales s'appliquent et comment on limite la propagation latérale.

▼ **Q45. Est-ce grave si mon schéma n'est pas « parfait » graphiquement ?**

Non : ce qui compte est la logique de sécurité (zones bien définies, sens des flux respecté, moindre privilège, justification claire).

Erreurs fréquentes de débutants

▼ Q46. Quelles sont les erreurs les plus courantes ?

Mettre l'AD ou une base de données en DMZ · autoriser la DMZ à initier librement des connexions vers le LAN · oublier le VLAN Management · mettre tous les serveurs dans le VLAN des utilisateurs · écrire des règles « any → any » · croire qu'un VLAN suffit · laisser le VLAN 1 par défaut partout · confondre pare-feu et antivirus · oublier que les règles sont lues de haut en bas.

Liens avec le reste du programme

▼ Q47. Pourquoi parle-t-on déjà de Zero Trust ?

La segmentation (DMZ + VLAN) est une première étape. Zero Trust va plus loin : « never trust, always verify », même à l'intérieur du réseau.

▼ Q48. Ce cours prépare-t-il à l'analyse de documents techniques ?

Oui : savoir lire un schéma d'architecture, repérer les faiblesses et proposer des améliorations est une compétence très demandée.

▼ Q49. Faut-il connaître des constructeurs précis ?

Non pour l'examen : on attend la compréhension des principes (zones, filtrage, moindre privilège). Les noms de solutions sont des exemples.

▼ Q50. Combien de VLAN au minimum dans un schéma type examen ?

Au moins : utilisateurs, serveurs/AD, management, guests, DMZ. Le VLAN « poubelle » est un plus.

▼ Q51. Comment se souvenir du sens des flux ?

« Du moins fiable vers le plus sensible = interdit par défaut. » Internet → DMZ possible (ports publiés) ; DMZ → LAN = non (ou flux très précis et justifiés).

> **Avant de rendre un schéma, posez-vous trois questions**
> 1) Où sont les données sensibles ? 2) Qui peut y accéder et comment ? 3) Si un serveur de la DMZ est compromis, jusqu'où l'attaquant peut-il aller ?

© 2026 **Twagirumukiza** — Support pédagogique BTS SIO 2 · Cybersécurité

Suivre Twagirumukiza sur LinkedIn ↗